

LLM-Driven Retrieval-Augmented Compliance Auditing for Cloud and Web Privacy

Aaron Joseph Jean
Department of Computer Science
University of Galway
Galway, Ireland
a.jean2@universityofgalway.ie

Abstract—Modern privacy regulations such as the EU General Data Protection Regulation (GDPR), India’s Digital Personal Data Protection Act (DPDP), and the California Consumer Privacy Act (CCPA) require organisations to provide clear, accurate disclosures about data collection and to obtain consent before non-essential tracking. Verifying that a website’s actual runtime behaviour matches the claims in its written privacy and cookie policies, however, remains a manual, error-prone, and unscalable task. This paper reviews research on automated privacy-compliance assessment across three modalities: natural-language processing of policy text, behaviour-to-policy inconsistency detection, and dynamic web consent auditing, together with the emerging use of large language models (LLMs) for legal reasoning. Rather than separating summary from critique, each research direction is reviewed alongside the specific limitation it leaves unresolved. The review shows that existing systems analyse policy text or runtime behaviour in isolation, while the few hybrid systems are confined to static analysis of compiled mobile binaries. From these observations we derive the central research gap: the absence of a unified, automated framework that ingests runtime web telemetry (HAR logs and JavaScript events), retrieves the relevant legal standard, and cross-references both against scraped policy text using retrieval-augmented generation (RAG) to detect real-world non-compliance. We then describe the design and implementation of such a framework. The pipeline stores regulations in a vector database chunked by article, collects behavioural evidence with an instrumented browser, and asks an LLM to judge each compliance dimension using the retrieved law, the scraped policy and the observed behaviour together. The framework is evaluated on twenty websites across six sectors and four jurisdictions, and every verdict is then checked mechanically against the telemetry it was derived from. The prototype detects contradictions between what a site’s policy claims and what the site does, and the verification found no case in which a behavioural claim was fabricated. We also report the failure modes found during testing, the guards added in response, and the limitations that the testing exposed in the pipeline itself.

Index Terms—privacy compliance, large language models, retrieval-augmented generation, cookie consent auditing, web telemetry, GDPR, natural language processing

I. INTRODUCTION

A. Background

With the rise of data privacy laws worldwide, including the EU’s General Data Protection Regulation (GDPR) and India’s Digital Personal Data Protection Act (DPDP), digital transparency has shifted from an ethical preference to a legal mandate. Under these frameworks, organisations are legally required to provide users with clear, detailed, and accurate

disclosures regarding data collection, processing purposes, and tracking technologies. Regulations such as the UK’s Privacy and Electronic Communications Regulations (PECR) further require explicit user consent before any non-essential tracking technology, such as cookies or device fingerprinting, is initiated. Empirical studies confirm that these requirements are frequently violated in practice: large-scale crawls of consent banners show that many sites set tracking cookies before any user interaction [1], [2], and automated analyses of written policies reveal widespread incompleteness and ambiguity [3], [4].

B. Motivation

Despite these legal frameworks, real-world compliance is highly fragmented. Many organisations use template-based privacy policies that do not accurately represent their actual technical practices [5]. Conversely, dynamic third-party scripts and marketing pixels are often added to websites without the knowledge of the primary site administrator, leading to silent data leaks and consent violations [2]. Compliance auditing is therefore still performed manually by legal experts and security auditors who inspect website code, examine consent pop-ups, monitor network requests, and read legal documents line by line. This approach is slow, expensive, and unscalable.

While automated tools have been developed to detect trackers or parse privacy policies, they typically operate in silos. Systems either analyse policy text using natural language processing (NLP) [3], [4], [6], or they inspect network traffic to identify tracking scripts and consent violations [1], [2], without cross-referencing the two. The few systems that attempt hybrid auditing are limited to mobile app ecosystems and rely on static program analysis [5], [7], [8], which is prone to false positives from unused libraries and cannot address the runtime complexities of web-based cookie consent banners. In parallel, large language models have begun to demonstrate strong legal-reasoning ability [9], [10], but have not been integrated with live behavioural evidence.

C. Problem Statement

The main research question addressed by this work is: *How can privacy compliance of web applications be measured in a continuous, contextual, and explainable manner that connects written disclosures (“notice”) to actual software execution*

(“practice”)?

D. Paper Organisation

The remainder of this paper is structured as follows. Section II presents an integrated literature review and gap analysis. Section III derives the framework design from the identified gaps and describes the working implementation, including the scoring algorithm. Section IV reports the evaluation: a case study, a batch of twenty sites, the verification of every finding against its telemetry, and the limitations this exposed. Section V sets out the threats to validity and the remaining evaluation, and Section VI concludes.

II. LITERATURE REVIEW AND IDENTIFIED GAPS

To build a sound academic foundation, a systematic search was conducted across IEEE Xplore, the ACM Digital Library, the USENIX proceedings, and Google Scholar, using keyword combinations such as *automated privacy policy compliance*, *cookie consent auditing GDPR*, *deep learning privacy policy NLP*, and *LLM legal compliance evaluation*. Papers were included only if they were published in a reputable peer-reviewed venue (e.g., USENIX Security, IEEE S&P, NDSS, ACL, EMNLP, NeurIPS, or PoPETs), presented an automated or semi-automated methodology, and collectively spanned both the textual analysis of legal documents and the technical analysis of software behaviour. This yielded ten representative works, organised below into four research directions. Following recent practice, each direction is reviewed together with the specific gap it leaves open, and Table I consolidates the comparison.

A. NLP and Machine Learning on Privacy Text

Analysing unstructured legal text is the first hurdle in automated compliance checking. Wilson et al. [3] established the foundational benchmark by creating the OPP-115 corpus, manually annotating 115 privacy policies with 23,000 fine-grained data practices and showing that statistical classifiers could automate policy categorisation; however, their models captured only shallow keyword associations rather than deep semantic meaning. Harkous et al. [4] advanced the field with Polisis, training custom word embeddings on 130,000 policies and using convolutional neural networks to classify policy segments at 88.4% accuracy, powering an automated question-answering assistant. Ravichander et al. [6] introduced the PrivacyQA dataset and showed that fine-tuned BERT models could extract answer spans, but reported a large gap between automated models and human legal experts. Crucially, all three rely entirely on the written policy text and have no mechanism to verify whether a site actually follows the stated practices. *Gap identified:* Text-only NLP methods assess what a policy *says*, but cannot verify what a system actually *does* [3], [4], [6].

Adopted in our framework: OPP-115’s ten data-practice categories [3] inform the requirement-type taxonomy used to tag legal chunks; Polisis’ segment-level classification [4] motivates routing only topically relevant policy sections to the scorer for long policies, and its finding that domain-specific embeddings

outperform general ones supports the choice of legal-domain embeddings; PrivacyQA’s demonstration that even legal experts disagree on unanswerable questions [6] motivates an explicit NOT-ADDRESSED verdict and confidence output rather than forced binary judgements.

B. Behaviour-to-Policy Inconsistency Detection

A second line of work checks whether disclosures are honest by analysing software behaviour. Zimmeck et al. [5] proposed a pioneering hybrid system for Android apps, combining text classification with static analysis of bytecode to detect undisclosed collection of sensitive identifiers. They later scaled this to over one million apps in the MAPS project [7], confirming the scale of violations but remaining specific to compiled Android binaries. Xiao et al. [8] shifted the focus to store-mandated privacy labels with Lalaine, characterising widespread non-compliance between Apple privacy labels and observed app behaviour. While these hybrid approaches validate the notice-versus-practice concept, static binary analysis suffers from false positives caused by dead code and, more importantly, cannot capture the dynamic, event-driven behaviour of web applications such as cookie setting and JavaScript-based tracking.

Gap identified: Hybrid notice-versus-practice auditing exists only for mobile ecosystems via static analysis, leaving dynamic web behaviour unaddressed [5], [7], [8].

Adopted in our framework: Zimmeck et al.’s design principle of a closed set of practices checkable in both text and behaviour [5] is mirrored in our mapping of each compliance dimension to a defined behavioural evidence type; MAPS’ conservative reporting of *potential* non-compliance [7] is retained in all generated output; and Lalaine’s typology of non-compliance, *neglect*, *contrary*, and *inadequate* disclosure [8], is adopted to classify every policy-versus-telemetry discrepancy the scorer reports.

C. Dynamic Web Cookie and Consent Auditing

Dynamic auditing of web tracking has been addressed through large-scale crawling. Trevisan et al. [1] performed a longitudinal study of EU cookie-law compliance, introducing an automated tool that detects tracking cookies set before user consent. Bouhoula et al. [2] extended this to the first general, automated, large-scale analysis of cookie-notice compliance, correcting the selection bias of earlier consent-management-platform-specific studies. Both provide strong empirical evidence of widespread violations, but they focus exclusively on observable network and consent behaviour and do not analyse or cross-reference the text of the websites’ written privacy policies.

Gap identified: Dynamic web auditing measures behaviour and consent signals but never reconciles them with the site’s written policy claims [1], [2].

Adopted in our framework: Trevisan et al.’s conservative operational definition of a profiling cookie (third-party, present in the intersection of two curated tracker lists, lifetime of at least one month) and their clean-profile, no-interaction visit

protocol [1] are adopted directly by the telemetry collector and HAR evidence extractor; their finding that violations are invariant to client location and browser justifies single-vantage scanning. From Bouhoula et al. [2], whose crawler and classifiers are open source, we reuse the notice-detection heuristics (filter-list matching combined with z-index inspection), the accept/reject/no-interaction action protocol, and feature-based classification of observed cookie purposes, which removes dependence on tracker blacklists; their conservatively tuned decision-tree mapping from observations to violation types informs our per-dimension verdict rules.

D. LLM-Based Legal and Compliance Evaluation

The most recent direction applies large language models to legal reasoning. Guha et al. [9] released LegalBench, a collaboratively built benchmark of 162 legal-reasoning tasks, demonstrating that modern LLMs can interpret legal clauses but evaluating them only on clean, isolated text. Xie et al. [10] took a significant step toward application, systematising 34 privacy-practice clauses from ten modern privacy laws and using an LLM-based pipeline to evaluate policies collected from over 100,000 websites at scale. While this confirms that LLMs can assess policy text against codified law, the evaluation still operates on policy text alone and does not ingest runtime behavioural evidence such as HAR network logs or JavaScript telemetry.

Gap identified: LLMs can reason over legal text and policies, but no framework feeds them live behavioural telemetry to ground their compliance judgements [9], [10].

Adopted in our framework: LegalBench’s privacy-related tasks [9] serve as a pre-deployment benchmark for selecting the scoring LLM, and its IRAC framing (issue, rule, application, conclusion) structures the scoring prompt: the compliance dimension is the issue, the retrieved article the rule, and the policy text plus behavioural evidence the facts to which it is applied. Xie et al.’s systematisation of 34 clauses across ten laws [10] is used to validate the coverage of our compliance dimensions, and their evaluation protocol, measuring per-clause F1 against an expert-annotated sample, is adopted as the evaluation design for the proposed framework.

E. Synthesis and Research Gap

Reading across the four directions, the reviewed work collectively establishes three findings: (i) written privacy policies are frequently incomplete and ambiguous and fail to disclose active tracking behaviour [3], [4], [6]; (ii) dynamic consent mechanisms on the web frequently set tracking cookies before consent is obtained, constituting measurable GDPR/PECR violations [1], [2]; and (iii) large language models can interpret legal clauses and assess policy text against codified law with growing accuracy, but only on text in isolation [9], [10].

Taken together, these findings expose a clear gap. Each strand masters a single modality, policy text, mobile behaviour, web behaviour, or legal reasoning, yet none reconciles the three sources a compliance judgement actually requires. Existing systems analyse the written policy text in isolation

(NLP/LLM approaches) or the software and web behaviour in isolation (dynamic crawls), and the few hybrid systems that match policy to behaviour are restricted to static analysis of compiled mobile binaries [5], [7], [8]. Consequently, there is currently **no unified, automated auditing framework that ingests runtime web behavioural evidence (network HAR logs and JavaScript event telemetry), retrieves the relevant legal standards, and cross-references them against scraped policy texts using LLM-driven retrieval-augmented generation (RAG) to detect real-world non-compliance and contradictions.** Bridging this divide between disclosed “notice” and observed “practice” for the dynamic web is the objective of the framework proposed next.

III. FRAMEWORK DESIGN AND IMPLEMENTATION

The design of the framework is derived directly from the gaps identified in Section II rather than chosen in the abstract. Each gap motivates a specific architectural decision, as summarised in Table II. The central observation is that the four research directions each master one modality, policy text, mobile behaviour, web behaviour, or legal reasoning, but none integrates the three sources of evidence that a real compliance judgement requires: the *law* (ground-truth regulation), the *notice* (the site’s written policy), and the *practice* (its observed runtime behaviour). The framework is therefore organised around triangulating these three sources for the dynamic web, the setting left unaddressed by prior work. All three phases below are implemented and running; Section IV reports first results from live audits.

A. Architecture Overview

The framework consists of three phases (Fig. 1):

- 1) **Legal Ingestion (pre-loaded):** Ground-truth regulations (GDPR, DPDP, CCPA, PECR, HIPAA) are parsed and chunked by legal unit (Articles/Sections) to preserve semantic coherence, embedded with a legal-specific model (*nlpueb/legal-bert-base-uncased*), and stored in a persistent vector database. This responds to G4: grounding the LLM in retrievable legal text.
- 2) **Runtime Collection:** For a target site, a headless browser (Playwright) simulates navigation, recording outbound requests as an HTTP Archive (HAR) and logging JavaScript/DOM events (consent clicks, canvas fingerprinting). It also crawls and extracts the written Privacy and Cookie policies into structured text. This responds to G2 and G3: capturing dynamic web behaviour and the policy text together.
- 3) **RAG Compliance Evaluation:** For each compliance dimension, the system retrieves relevant legal articles from the vector store, reads the extracted policy claims, parses the behavioural evidence, and prompts an LLM with the combined *law + notice + practice* context to output a score, cite the breached article, and recommend a fix. This responds to G1: verifying practice against stated notice.

TABLE I
REPRESENTATIVE RELATED WORK ON AUTOMATED PRIVACY-COMPLIANCE AUDITING

Ref	Focus	Key Contribution	Modality	Dataset / Evaluation	Limitation
[3]	Policy-text corpus	OPP-115 annotated corpus; statistical classification of data practices	Policy text (NLP)	115 annotated policies	Shallow semantics; no behaviour check
[4]	Deep-learning policy analysis	Polisis CNN classifier (88.4%) and QA assistant	Policy text (NLP)	130k privacy policies	Text-only; cannot verify site behaviour
[6]	Policy QA	PrivacyQA dataset; BERT span extraction	Policy text (NLP)	1,750 questions	Large human-model gap; extractive only
[5]	Notice vs. practice (mobile)	Hybrid text + static bytecode analysis	Mobile static	17,991 Android apps	Static; mobile only; false positives
[7]	Compliance at scale	MAPS large-scale automated analysis	Mobile static	1M+ Android apps	Mobile binaries; no dynamic web consent
[8]	Privacy-label non-compliance	Lalaine measures label vs. behaviour gaps	Mobile dynamic/static	iOS apps + label data	iOS labels; not web telemetry
[1]	Cookie-law auditing	Detects pre-consent tracking cookies	Web network	Longitudinal EU crawl	Ignores written policy text
[2]	Cookie-notice compliance	General large-scale consent compliance analysis	Web network/consent	Large-scale web crawl	No policy-text cross-reference
[10]	LLM policy evaluation	LLM assessment of 34 clauses vs. 10 laws	Policy text (LLM)	100k+ website policies	Policy text only; no runtime telemetry
[9]	Legal-reasoning benchmark	LegalBench: 162 legal-reasoning tasks	Legal text (LLM)	162 tasks, 20 LLMs	Isolated clean text; not applied to web

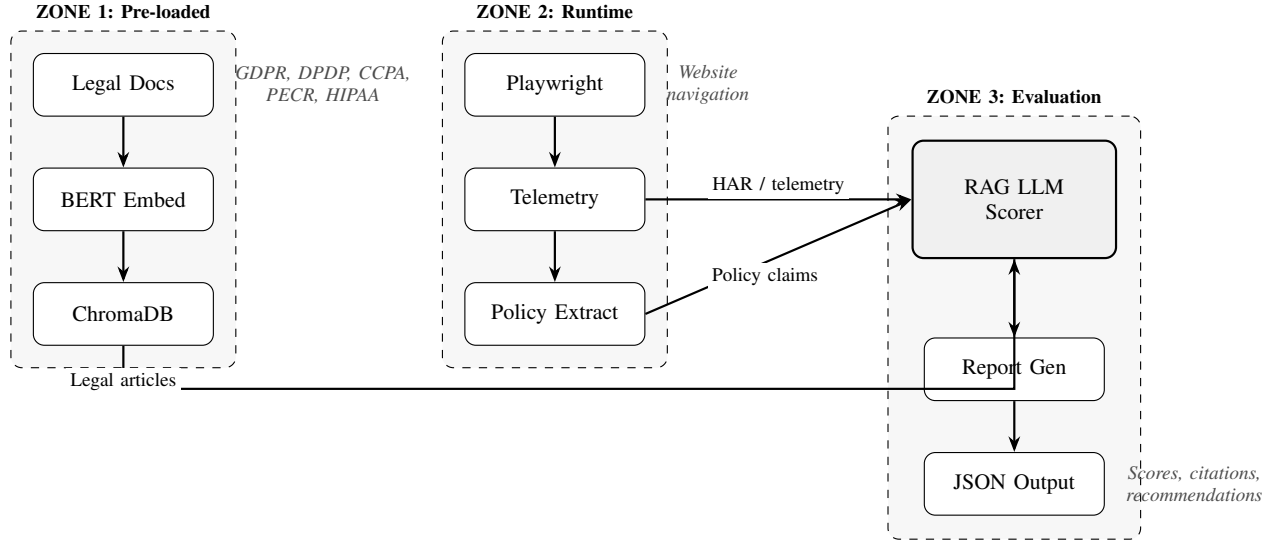


Fig. 1. Proposed architecture. Three phases converge on a RAG-based LLM scorer: (1) pre-loaded legal ingestion into a vector store, (2) runtime telemetry and policy collection, and (3) compliance evaluation that triangulates retrieved legal articles, HAR/telemetry evidence, and extracted policy claims to produce explainable scores and recommendations.

B. Design Rationale

Three decisions follow directly from the literature. First, *legal-specific embeddings* are used because general-purpose models capture only shallow associations on legal text [3], [4]; domain embeddings give terms such as “controller” and “data subject” appropriate legal semantics, improving retrieval quality. Second, *retrieval-augmented generation* is preferred over prompting an LLM alone because, while LLMs can reason about law [9], [10], ungrounded generation risks hallucinated citations; retrieving the exact article before scoring yields traceable, evidence-backed judgements. Third, *runtime instrumentation* (rather than static analysis) is required because the unaddressed modality is dynamic web behaviour, where

consent state changes with user interaction, something static mobile analysis [5], [7] cannot observe and text/consent-only studies [1], [2] do not reconcile with policy text. Together these choices make the “notice-to-practice” verification both possible and explainable, the combination absent from all reviewed work.

C. Implementation Status and Practical Tools

The prototype is implemented in Python and organised as independently testable command-line modules, orchestrated end-to-end by a local web frontend:

- **Legal ingestion (complete):** regulations are parsed from official HTML/PDF sources (EUR-Lex, legisla-

TABLE II
MAPPING OF IDENTIFIED GAPS TO DESIGN DECISIONS

Gap	Limitation in prior work	Design response
G1	Text-only NLP cannot verify behaviour [3], [4], [6]	Cross-reference policy claims against runtime telemetry (notice vs. practice)
G2	Hybrid auditing limited to static mobile binaries [5], [7], [8]	Dynamic headless-browser instrumentation capturing HAR and JavaScript events
G3	Web auditing ignores written policy text [1], [2]	Couple consent/network evidence with scraped policy extraction per site
G4	LLMs reason over law but lack grounded evidence [9], [10]	RAG over a legal vector store grounds each LLM judgement in retrieved articles

tion.gov.uk, MeitY) and chunked by legal unit using a multi-statute heading grammar (*Article 7* for GDPR/DPDP, 6.—(1) UK-SI numbering for PECR, 1798.100. for the CCPA); heading-only fragments are discarded. GDPR yields exactly 99 article chunks. Chunks carry regulation, article, requirement-type and severity metadata and are embedded into a persistent ChromaDB collection.

- **Runtime collection (complete):** a Playwright-instrumented Chromium visit records the HAR, hooks fingerprinting APIs (canvas, WebGL, AudioContext, WebRTC, battery, fonts) via an injected trap script, tags consent-related UI elements, and extracts policy links; a separate scraper exports the site’s privacy and cookie policies as markdown. The evidence extractor applies the conservative profiling-cookie rule of [1] (third-party $\wedge$ present in the intersection of two tracker lists $\wedge$ lifetime ≥ 30 days) and also recovers JavaScript-set cookies from browser context state, which header-only analysis misses.
- **RAG evaluation (complete):** per dimension, the scorer retrieves law chunks (metadata-filtered semantic search plus deterministic *dimension-anchored* fetches of the dimension’s known articles), injects the full policy text and the selected behavioural evidence, and prompts an LLM (temperature 0, strict JSON) for a verdict. The scorer is provider-agnostic (OpenAI and Anthropic backends).
- **Reporting (complete):** verdicts are aggregated severity-weighted and rendered as a self-contained HTML report; a local web frontend runs the full pipeline per URL with a live stage log.

During implementation the embedding model had to be changed. Legal-domain BERT (*nlpaueb/legal-bert-base-uncased*) was chosen initially for its legal vocabulary, but retrieval tests showed near-uniform cosine similarities (about 0.72 for every chunk) and effectively random ranking. It is a raw masked-language model without sentence-level training, so the vocabulary advantage did not help retrieval. It was replaced with a sentence-trained encoder (*all-mpnet-base-v2*), after which the expected articles ranked first.

Algorithm 1 Per-dimension RAG compliance scoring

Require: target site s ; dimensions D ; regulations R ; vector store V
Ensure: severity-weighted report with article-cited verdicts

```

1:  $H \leftarrow \text{COLLECTTELEMETRY}(s)$   $\triangleright$  HAR, JS alarms, consent UI
2: if  $H$  is degenerate (bot-blocked / empty capture) then
3:   return INSUFFICIENTDATA  $\triangleright$  refuse to score garbage input
4: end if
5:  $E \leftarrow \text{EXTRACTEVIDENCE}(H)$   $\triangleright$  profiling-cookie rule [1]
6:  $P \leftarrow \text{SCRAPEPOLICIES}(s)$ 
7: for each dimension  $d \in D$  do
8:    $e_d \leftarrow$  evidence in  $E$  matching  $d$ ’s evidence keys
9:   if  $P = \emptyset$  and  $e_d = \emptyset$  then
10:    verdict  $\leftarrow$  NOT-ADDRESSED  $\triangleright$  deterministic guard; no LLM call
11:   else
12:     $L_d \leftarrow$  anchored articles( $d$ )  $\cup$  filtered search( $V, d, R$ )
13:    verdict  $\leftarrow \text{LLM}_{T=0}(\text{IRAC: issue } d, \text{rule } L_d, \text{facts } P + e_d)$ 
14:    validate JSON; clamp score/confidence; check verdict enum
15:   end if
16: end for
17: return severity-weighted aggregate + per-dimension verdicts

```

D. Scoring Strategy

For each dimension the LLM returns a structured judgement rather than a bare score. It contains: a **score** (0–100, anchored to a rubric), a **verdict** (PASS, FAIL, PARTIAL, or NOT-ADDRESSED) with a **confidence** value, following the abstention lesson of [6]; the **breached article**, quoted from the retrieved text only; the **policy claim** quoted from the notice; the **behavioural evidence** relied upon; a **discrepancy type** (*neglect / contrary / inadequate*, the typology of [8]); and a plain-English explanation and recommended fix. Dimension scores are aggregated using severity weights (critical 3, high 2, medium 1, low 0.5), with NOT-ADDRESSED dimensions excluded; all output is framed as *potential* non-compliance [7].

The full scoring procedure, including the two deterministic guards added after the error analysis of Section IV, is given in Algorithm 1.

E. Techniques and Artifacts Adopted from Reviewed Work

Beyond motivating the gap, the reviewed papers contribute reusable techniques, datasets, and open-source artifacts that are incorporated into the implementation. Table III consolidates this mapping from source to framework component. Publicly released artifacts are reused where licences permit: the crawler and classifiers of [2], the measurement tool and dataset of [1], the OPP-115 corpus [3], the PrivacyQA dataset [6], and the LegalBench task suite [9].

TABLE III
ELEMENTS ADOPTED FROM REVIEWED WORK INTO THE PROPOSED
FRAMEWORK

Ref	Adopted element	Framework component
[1]	Conservative profiling-cookie rule (dual tracker-list intersection, ≥ 1 -month lifetime); clean-profile no-interaction visits	HAR evidence extractor; telemetry collection protocol
[2]	Notice-detection heuristics; accept/reject action protocol; feature-based cookie-purpose classification	Consent-interaction module; violation decision rules
[3]	Ten data-practice categories; annotated corpus	Legal-chunk metadata taxonomy; evaluation data
[4]	Segment-level policy classification; domain-specific embeddings	Section routing for long policies; embedding choice
[6]	Unanswerability of some policy questions	NOT-ADDRESSED verdict; confidence output
[5]	Closed set of practices checkable in text and behaviour	Dimension-to-evidence-type mapping
[7]	Tiered analysis for scale; “potential” non-compliance phrasing	Two-tier LLM usage; report language
[8]	Neglect / contrary / inadequate disclosure typology	Discrepancy classification in scorer output
[9]	Privacy-task benchmark; IRAC prompt framing	Scorer-LLM selection; scoring prompt structure
[10]	34-clause systematisation over ten laws; expert-annotated F1 protocol	Dimension coverage validation; evaluation design

IV. EVALUATION

The framework was evaluated in three stages. A single site was audited in detail to establish that the pipeline produces usable findings, a batch of twenty sites was then audited to measure coverage and behaviour across sectors, and every verdict in that batch was checked mechanically against the telemetry it was derived from. The third stage exists because an LLM-based auditor is only useful if its findings can be shown to come from the evidence rather than from the model. All figures below are from the run of 16 August 2026 using gpt-4o-mini at temperature 0.

A. Case Study: Live Audit of a News Website

The prototype’s first end-to-end audit targeted *www.independent.ie* (news media — the category with the highest violation rates in [1]), scored against GDPR and PECR with a clean-profile, no-interaction visit. The telemetry recorded **22 third-party domains** contacted before any consent, including **15 tracker eTLD+1s** (among them doubleclick.net, taboola.com and google-analytics.com), **4 fingerprinting API calls** (WebRTC $\times 3$, Battery API), and **zero pre-consent profiling cookies** under the strict detection rule. Table IV summarises the verdicts.

This case shows why the three sources need to be combined. The site’s consent platform does withhold cookies,

TABLE IV
AUDIT VERDICTS FOR WWW.INDEPENDENT.IE (GDPR + PECR)

Dimension	Verdict	Key finding
Tracking without consent	FAIL (18)	tracker requests + fingerprinting before any consent; discrepancy: <i>contrary</i>
Disclosure of third parties	FAIL	no recipients named in policy; 15 tracker domains observed
Pre-consent tracking cookies	PARTIAL (50)	no profiling cookies observed; consent UI present

TABLE V
COVERAGE OUTCOMES OVER TWENTY SITES

Outcome	Sites	Cause
Scored	15	—
Capture refused	2	bot protection; degenerate capture rejected by the sanity gate
Collection timed out	2	slow sites exceeding the collector budget
Insufficient data	1	no policy retrieved and no relevant events observed

so a cookie-only audit in the style of [1] would find little. However, tracker requests and fingerprinting calls still run before consent, and the written policy does not name any of the observed recipients. The contradiction only becomes visible when the law, the notice and the behaviour are examined together.

B. Batch Evaluation Across Twenty Websites

To test the pipeline beyond a single case, twenty sites were selected across six sectors and four jurisdictions. The selection deliberately includes sectors at both ends of the range reported by Trevisan et al. [1], namely news media and government, and two sites known to use bot protection so that the failure path would also be exercised. Each site was audited on three dimensions (pre-consent tracking, tracking without consent, disclosure of third parties) against GDPR and PECR, with DPDP added automatically for Indian domains. The harness records the outcome of every stage, so sites that fail are counted rather than silently dropped.

Table V gives the coverage outcome. Fifteen of twenty sites produced a scored report. Two sites (irctc.co.in and ndtv.com) were refused by the capture sanity gate, which is the intended behaviour: both returned effectively empty pages under a headless browser, and scoring such a capture would produce confident findings about nothing. A further two sites exceeded the collection timeout, and one site produced a report of INSUFFICIENT-DATA because neither a policy nor relevant behavioural events could be obtained. The overall capture failure rate is therefore 10%, and the rate at which the pipeline declines to give a compliance opinion is 25%.

Table VI reports the mean score by sector. The ordering

TABLE VI
MEAN SCORE BY SECTOR (HIGHER IS MORE COMPLIANT)

Sector	Sites	Mean	FAIL verdicts
Government	1	53.0	0 / 3
SaaS	1	44.0	0 / 3
Education	4	29.2	7 / 12
News	6	24.3	8 / 18
Social	1	25.0	1 / 3
E-commerce	2	3.0	4 / 6

is broadly consistent with the published sector pattern: the government site scores highest and news media sits in the lower half. The result should not be over-read. Several sectors are represented by a single site, and the e-commerce mean is depressed by the confound discussed in Section IV-D. Across all scored sites the mean was 26.1 and the range 0 to 53, but only seven distinct scores occurred in fifteen reports. The model anchors on the round values of the scoring rubric rather than using the full scale, so the scores are better treated as an ordinal ranking than as interval measurements.

At the level of individual dimensions, tracking without consent produced ten FAIL verdicts, four PARTIAL and one PASS, and disclosure of third parties produced seven FAIL and eight PARTIAL. Pre-consent tracking produced only three FAIL verdicts and ten PARTIAL, because the strict profiling-cookie rule rarely fires on sites that operate a consent platform. That dimension therefore carries less discriminating information than the other two, which is a useful finding in itself: the cookie-based test that the earlier literature relies on is the weakest of the three signals on the current web, while request-level and disclosure-level evidence separate sites much more clearly.

C. Verifying Findings Against the Telemetry

Compliance findings produced by a language model are only credible if each claim can be traced to the artefact it came from. A verification tool was therefore written that re-checks every verdict mechanically, without invoking a model, so that the check itself cannot fabricate. To make this possible the scorer records, for every verdict, which legal articles were retrieved and the exact rule text that was placed in the prompt.

Five checks are applied to each verdict. The first confirms that the cited article was actually retrieved for that dimension. The second confirms that the quoted legal requirement appears in the retrieved rule text. The third confirms that the quoted policy claim appears in the scraped policy. The fourth confirms that every domain, cookie name and count named in the finding exists in the evidence extracted from the HAR file. The fifth applies internal consistency rules, for example that a NOT-ADDRESSED verdict carries no breach citation and that a discrepancy type is asserted only when both a policy quotation and behavioural evidence are present. Quotation matching normalises whitespace and quotation marks and accepts elided quotations, but reports anything below a high similarity threshold as a paraphrase rather than a quotation.

Across the fifteen scored reports the verification flagged five claims, and the mean grounding rate, that is, the proportion

TABLE VII
ATTRIBUTION OF THE FIVE FLAGGED CLAIMS

Cause	Flags	Interpretation
Over-claim on missing input	4	non-disclosure asserted about a policy that was never retrieved
Unlocatable quotation	1	quoted requirement not located in the retrieved article text
Fabricated behavioural claim	0	no invented domain, cookie or count

of dimensions in which every claim could be traced to its source, was 86.7%. Each flag was inspected individually and the attribution is given in Table VII. Four occurred on sites where no policy document could be retrieved, and in every case the model had asserted a discrepancy type of *neglect*, that is, that a practice had not been disclosed in a document it had never been shown. Non-disclosure cannot be established from an unread policy, so this is genuine over-claiming; it is now rejected by the consistency rules and constrained in the prompt. The remaining flag is a paraphrase of a definition of consent that appears in GDPR Article 4(11) rather than in the retrieved Article 7 text, so the statement is legally accurate but is not a quotation of the rule that was supplied.

Two defects were also found in the verification tool itself during this analysis and corrected: names of fingerprinting APIs such as `navigator.getBattery` matched the pattern used to detect domain names, and elided quotations were tested after their ellipsis markers had been removed, so valid quotations spanning a gap were reported as unmatched. Both inflated the apparent error rate of the model. This is worth recording because it illustrates a general difficulty in evaluating a generative system: the measuring instrument requires validation of its own.

The result that matters for the reliability of the approach is the last row of Table VII. No claim was found in which the model asserted a behavioural event that did not appear in the telemetry. Every domain, cookie and fingerprinting call named in the fifteen reports was present in the corresponding HAR evidence. The errors that did occur were of two kinds: quoting loosely, and reasoning about a document that had not been retrieved. Both are addressable by constraining the prompt, and both are detectable without human review, which is what makes the check usable at scale.

D. Limitations Revealed by Testing

The batch exposed three limitations that were not visible from a single case study.

Policy retrieval dominates the score. Sites for which no policy document was retrieved scored 0.0 on average, while sites with one or two policy documents scored 32.6. A gap of roughly thirty-three points is attributable to the auditing pipeline’s own retrieval coverage rather than to the behaviour of the site. Two causes were identified: policies hosted on a parent company domain, which the same-domain preference

of the scraper misses, and pages that render policy links only after JavaScript execution. Results for sites without a retrieved policy must therefore be reported separately, and are excluded from the sector means where noted.

Bot protection bounds the achievable coverage. Two sites could not be captured at all and two more exceeded the collection budget. Because the sanity gate refuses to score a degenerate capture, this manifests as reduced coverage rather than as wrong answers, which is the preferable failure mode, but it does mean that the sites most likely to engage in aggressive tracking are also among the hardest to audit.

Jurisdiction determines the applicable instrument. The ePrivacy Directive is transposed nationally, so the cookie-consent rule differs by country even though the GDPR applies uniformly across the Union. An early version of the batch scored every site against the GDPR and the UK Privacy and Electronic Communications Regulations, which is incorrect for the eleven Irish sites in the sample: Ireland transposed the Directive through S.I. 336/2011, whose Regulation 5(3) is the operative provision and is enforced by the Data Protection Commission. The framework now selects instruments by jurisdiction, and the Irish instrument has been ingested alongside the others; the results reported in this section, however, predate that correction, so the ePrivacy citations for Irish sites in this run name the UK instrument. The GDPR findings, which account for the disclosure dimension, are unaffected, and re-scoring the Irish sample under S.I. 336/2011 is immediate remaining work. The episode is worth recording because it is a failure mode that a single-jurisdiction evaluation would never expose, and because cross-border auditing tools that assume one ePrivacy text are subject to it.

A related observation supports the retrieval-based design. The corpus holds consolidated legislation, so the ingested PECR text includes the substitution of Regulation 6 and the insertion of Schedule A1 by the Data (Use and Access) Act 2025, in force from February 2026, which moves statistical cookies from an opt-in to an opt-out basis under defined conditions. The system therefore reasons over the amended rule without any change to the model, because the law is held in the vector store rather than in model weights. A system that had internalised the earlier rule during training would continue to apply it.

Score granularity is coarse. With seven distinct values across fifteen sites, the numeric score should not be treated as a continuous measurement. The verdict labels and the underlying evidence carry the information; the score is best used to rank sites rather than to quantify the distance between them. Testing surfaced three failure modes, each fixed at the layer that caused it and re-verified:

- 1) **LLM over-condemnation.** In an early run the pre-consent-tracking dimension returned FAIL (score 0, confidence 1.0) although no profiling cookies had been observed: the model invented cookie installations and misread the audit protocol line (“consent interaction: none”) as the *site* lacking a consent mechanism. *Fix:* evidence-discipline rules in the system prompt (cite only

listed events; empty evidence forbids behavioural violations) and an explicit audit-protocol note in the evidence block. On re-run the verdict flipped to PARTIAL with policy-only reasoning and `behavioral_evidence: null`.

- 2) **Retrieval near-miss.** One verdict cited GDPR Art 19 (rectification notification) instead of Art 13(1)(e) (disclosure of recipients). Semantic similarity had ranked the wrong “recipients” article first, and the model correctly obeyed the instruction to cite only retrieved text. *Fix:* dimension-anchored retrieval (Section III-C). This also supports the grounding design: the failure moved from the generation step to the retrieval step, where it could be fixed deterministically.
- 3) **Degenerate capture.** A bot-blocked site (www.ndtv.com) produced an empty capture (1 request, 0 UI elements), and the scorer initially issued confident FAIL verdicts on nothing, treating the unretrieved policy as proof that none exists. *Fix:* a capture sanity gate that refuses to score degenerate scans, and an insufficiency guard: with no policy text and no behavioural events the verdict is forced to NOT-ADDRESSED without invoking the LLM, and the overall verdict becomes INSUFFICIENT-DATA.

Together with the embedder change in Section III-C, these are four documented findings from the implementation phase. A fifth was added by the batch: on sites where the policy could not be retrieved, the model inferred non-disclosure from the absence of a document rather than abstaining, which is now prevented.

V. THREATS TO VALIDITY AND REMAINING EVALUATION

Three threats to validity follow from the design of the study. The ground truth for compliance is not established independently: the batch measures what the system reports and whether those reports are grounded in the evidence, but not whether a lawyer would agree with the verdicts. Establishing that requires hand annotation, which is the principal item of remaining evaluation and follows the per-clause protocol of [10]: a sample of sites annotated against the article text, from which per-dimension precision, recall and F1 are computed. A single annotator is a known weakness, acknowledged in the light of the expert disagreement reported by [6].

The second threat is sample size. Six sectors across fifteen scored sites is sufficient to expose pipeline limitations, but not to make claims about sector-level compliance rates; several sectors are represented by a single site.

The third threat is that a single model was used throughout. Model selection has not yet been made empirically, and the intended comparison uses the LegalBench privacy tasks [9] together with the annotated sample. Reproducibility is supported by temperature-0 scoring, pinned tracker lists and versioned prompts; repeat-run variance is to be reported alongside the F1 results.

VI. CONCLUSION AND FUTURE WORK

This paper reviewed automated privacy-compliance research across four directions and showed that no prior system integrates the three evidence sources a compliance judgement requires: the law, the site’s written notice, and its observed runtime practice. We then presented the design and implementation of a framework that closes this gap for the dynamic web. Regulations are chunked by legal unit into a vector store, behavioural evidence is captured with an instrumented browser, and an LLM scores each compliance dimension using the retrieved law, the scraped policy and the observed behaviour under an IRAC structure. In live audits the prototype detected a site whose trackers and fingerprinting run before consent while its policy names no recipients, which no single-modality system could have shown. A batch of twenty sites produced fifteen scored reports, with the remainder declined rather than guessed at. Mechanical verification of every verdict against its own telemetry gave a grounding rate of 86.7% and found no case in which the model asserted a behavioural event that the evidence did not contain; the errors that did occur were reasoning about policies that had not been retrieved, and one paraphrase of a definition drawn from an article that had not been supplied. Both are correctable in the prompt and both are detectable without human review. Testing also showed that the pipeline’s own retrieval coverage, rather than site behaviour, accounts for roughly thirty-three points of score difference where policies could not be obtained, which is the most significant limitation of the current system. Future work includes consent-banner interaction with accept/reject differential testing, following [2]; the evaluation plan of Section V; and post-login observation, i.e. comparing what a site collects inside an authenticated session with the consent that was given, which none of the reviewed papers address.

VII. USE OF AI

In line with the capstone guidelines, the use of AI tools is declared. AI assistance (large language model tools) was used during this project as a coding and writing aid: for LaTeX formatting and structuring of this document, for drafting and revising sections of the text, and for assistance during the implementation and debugging of the prototype. The research direction, design decisions and experiments are the author’s own.

ACKNOWLEDGMENT

The author thanks Dr. Ihsan for his supervision throughout this capstone project, and in particular for the critique at the interim review that led to the multi-site evaluation and the verification of findings against the collected telemetry reported in Section IV. The author also acknowledges the maintainers of the Disconnect and Ghostery tracker databases, and the Irish Statute Book, EUR-Lex and legislation.gov.uk services, whose openly published texts made the legal corpus possible.

REFERENCES

- [1] M. Trevisan, S. Traverso, E. Bassi, and M. Mellia, “4 years of eu cookie law: Results and lessons learned,” *Proceedings on Privacy Enhancing Technologies (PoPETs)*, vol. 2019, no. 2, pp. 126–145, 2019.
- [2] A. Bouhoula, K. Kubicek, A. Zac, C. Cotrini, and D. Basin, “Automated large-scale analysis of cookie notice compliance,” in *Proc. 33rd USENIX Security Symposium*, pp. 1723–1739, 2024.
- [3] S. Wilson, F. Schaub, A. A. Dara, F. Liu, S. Cherivirala, P. G. Leon, M. S. Andersen, S. Zimmeck, K. M. Sathyendra, N. C. Russell, T. B. Norton, E. Hovy, J. R. Reidenberg, and N. Sadeh, “The creation and analysis of a website privacy policy corpus,” in *Proc. 54th Annual Meeting of the Association for Computational Linguistics (ACL)*, pp. 1330–1340, 2016.
- [4] H. Harkous, K. Fawaz, R. Lebre, F. Schaub, K. G. Shin, and K. Aberer, “Polisis: Automated analysis and presentation of privacy policies using deep learning,” in *Proc. 27th USENIX Security Symposium*, pp. 531–548, 2018.
- [5] S. Zimmeck, Z. Wang, L. Zou, R. Iyengar, B. Liu, F. Schaub, S. Wilson, N. Sadeh, S. M. Bellovin, and J. R. Reidenberg, “Automated analysis of privacy requirements for mobile apps,” in *Proc. Network and Distributed System Security Symposium (NDSS)*, 2017.
- [6] A. Ravichander, A. W. Black, S. Wilson, T. Norton, and N. Sadeh, “Question answering for privacy policies: Combining computational and legal perspectives,” in *Proc. Conf. on Empirical Methods in Natural Language Processing (EMNLP-IJCNLP)*, pp. 4947–4958, 2019.
- [7] S. Zimmeck, P. Story, D. Smullen, A. Ravichander, Z. Wang, J. R. Reidenberg, N. C. Russell, and N. Sadeh, “Maps: Scaling privacy compliance analysis to a million apps,” *Proceedings on Privacy Enhancing Technologies (PoPETs)*, vol. 2019, no. 3, pp. 66–86, 2019.
- [8] Y. Xiao, Z. Li, Y. Qin, X. Bai, J. Guan, X. Liao, and L. Xing, “Lalaine: Measuring and characterizing non-compliance of apple privacy labels,” in *Proc. 32nd USENIX Security Symposium*, 2023.
- [9] N. Guha, J. Nyarko, D. E. Ho, C. Ré, A. Chilton, A. Narayana, A. Chohlas-Wood, *et al.*, “Legalbench: A collaboratively built benchmark for measuring legal reasoning in large language models,” in *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*, 2023.
- [10] Q. Xie, K. Ramakrishnan, and F. Li, “Evaluating privacy policies under modern privacy laws at scale: An llm-based automated approach,” in *Proc. 34th USENIX Security Symposium*, 2025.